Grupo Bimbo, S.A.B. de C.V. | ESG Scores Raw Data

BMV:BIMBO A (MI KEY: 4276592; SPCIQ KEY: 877906; TCUID: 53231)

Additional Disclosure

Year: Methodology Year: 2024
Question: Information Security Management Programs
Include Modeled Scores : Yes

Information Security Management Programs

Question

Does the company have programs on information security management?

Rationale

Due to the current trend of digitization, including but not limited to cloud computing, online marketplaces and payments, etc., it is crucial that access to networks, IT systems and data is assured at all times. As a result, lower than agreed upon system performance or service disruptions can result in higher costs and reputational risk for companies. The main risks stem from technical failure, human error, malicious attacks, weather events, natural disasters or terrorist attacks. Managing such risks, including contingency plans, is crucial to ensuring business continuity.

Over the past decade, the number of information security breaches has grown exponentially with some attacks reaching unprecedented scales and the cyber threat landscape continues to grow and evolve, abusing existing and new technologies and exploiting vulnerable users. These incidents and the related costs have shown that information security/cybersecurity has become a financially material issue that must be diligently managed to protect corporate value. The costs of cyberattacks are manifold and can impact the company in different ways. Internal costs are operational costs and relate to dealing with cybercrime and incidence prevention. External costs include the consequences of the cyber-attack such as the loss or theft of sensitive information, operations' disruption, fines and penalties, infrastructure damage or revenue losses due to loss of customers. Thus, ensuring the security and resilience of netw

The question focuses on how well companies are prepared to prevent major IT infrastructure and information security/cybersecurity incidents and if they can react appropriately in the event of such events.

Performance Summary	
Question Level Company Performance	
Question Weight	
Year-on-Year Change	
Industry Average Score	
Industry Highest Score	

The question layout and the company's verified information is provided below. No information is shown if the company did not provide any information or if it opted out of sharing non-public information.

Additional Question Guidance & Information Display

Key Definitions

IT security: IT security is the process of implementing measures and systems designed to securely protect and safeguard information utilizing various forms of technology. IT security is thus considered a bit broader than cybersecurity.

Information System: Applications, services, information technology assets, or other information handling components (according to ISO).

Cybersecurity: Cybersecurity is the body of technologies, processes and practices designed to protect networks, systems, computers, programs and data from attack, damage or unauthorized access (according to SEC).

Information security: The protection of information and information systems from unauthorized access, use, disclosure, disruption, modification, or destruction in order to provide confidentiality, integrity, and availability (according to NIST).

Vulnerability analysis: The analysis that a company conducts for defining, identifying, classifying, and prioritizing vulnerabilities in computer systems, applications, and network infrastructures. This provides the organization doing the assessment with the necessary knowledge, awareness and risk background to understand the threats to its environment and react appropriately.

Information security breaches: These are defined as unauthorized access to computer data, applications, networks, devices, protected systems and data. Cybercriminals or malicious applications bypass security mechanisms to reach restricted areas.

Number of clients, customers and employees affected: The entity shall disclose the total number of unique clients, customers and employees who were affected by data breaches, which includes all those whose personal data was compromised in a data breach (accounts that the entity cannot verify as belonging to the same client, customer or employee shall be disclosed separately).

Important note: Throughout the whole criterion we always refer to IT security, cybersecurity or information security according to the definitions above. For the appraisal of the criterion we will treat "IT security", "information security" and "cybersecurity" equally.

Data Requirements

Vulnerability analysis: We expect to see evidence that a vulnerability analysis was conducted and that this analysis includes simulated hacker attacks. The analysis and testing should be performed by a third party with appropriate certification.

Please note: Non-IT companies can also calculate the percentage of certified IT infrastructure based on the percentage of certified IT products by external vendors.

Supporting evidence:

- The document(s) you attached will be used to verify the qualitative part of your response. If a question text field is available, a comprehensive answer in that field can be accepted instead of a supporting document. Any qualitative response that cannot be verified in the attached document(s) or via the information provided in the related question text field (if available) will not be accepted.
- Quantitative figures provided in the response do not need supporting evidence. You may still provide a reference using the reference clip. This could include examples of the underlying calculations or approaches to data aggregation used to compile the provided quantitative information.
- The supporting documents do not need to be available in the public domain.

References

External management standards and frameworks include but are not limited to:

ISO/IEC 27001:2022 – Information technology – Security techniques – Information security management systems – Requirements

Barrett, M. (2020), Framework for Improving Critical Infrastructure Cybersecurity Version 1.1, NIST Cybersecurity Framework, [online], https://doi.org/10.6028/NIST.CSWP.04162018, https://www.nist.gov/cyberframework

Standards & Frameworks

ESG Disclosure Standards (China) - G.2.1.5 Data security

Data View

No information was found in the public domain.

Questionnaire

This question assesses if companies have the right processes in place to prevent IT system interruptions and cyberattacks and if they are well-prepared to react in case of such events.

1. ○

   Incident Response

   Do you have business continuity / contingency plans and incident response procedures in place and how often do you test them? Please provide supporting evidence of how often these plans/procedures are tested.

   1. ○

      Yes, and we test them at least semi-annually
   2. ○

      Yes, and we test them at least annually
   3. ○

      Yes, but frequency is less than yearly or not specified
   4. ○

      No, we do not have such plans and procedures in place

   Certification

   Is your IT infrastructure and information security management system certified to ISO 27001, NIST or similar?

   1. ○

      Yes, the following percentage of our IT infrastructure has been certified:
   2. ○

      No, our IT infrastructure has not been certified.

   External Verification and Vulnerability Analysis

   Please indicate if there are other additional procedures implemented to assure the security of the IT infrastructure / information security management systems.

   1. ☐

      Our IT infrastructure and information security management systems have been audited by external auditors in the last fiscal year. Please provide letter of opinion from the external auditor.
   2. ☐

      We conduct third-party vulnerability analysis. Please provide supporting evidence:
   3. ☐

      As part of third-party vulnerability analysis, we conduct simulated hacker attacks. Please provide supporting evidence:

   Breaches

   Has your company experienced breaches of information security?

   1. ○

      We collect data on information security/cybersecurity breaches.

      Please note that if you did not have any information breaches, 0 should be entered in the corresponding box in the table. If you do not know the information, please leave the box empty. See the information text for more information.

      Supporting evidence:

	2023
Total number of information security breaches	
Total number of clients, customers and employees affected by the breaches	

   2. ○

      We do not collect data on information security/cybersecurity breaches.
2. ○

   We do not have processes and infrastructure in place to prevent and/or respond to cyberattacks.
3. ○

   Not applicable. Please provide explanations in the comment box below.
4. ○

   Not known

Confidential additional comments

Use the text field below only in the following cases: (i) to describe significant changes in data or calculation methodology compared to last year's submission, (ii) to explain why a question is not applicable to your company's business model, (iii) to explain if your data deviates from the unit or format requested, or (iv) to provide supporting notes on translations of non-English references.